

CVE-2026-35616

Fortinet FortiClient EMS Pre-Authentication API Bypass — Active Exploitation & EKZ Infostealer Campaign

Vulnerability Intelligence Report | Published: 28 May 2026 | TLP: AMBER

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Currency: Information is based on publicly available sources at time of generation. Verify all details against the latest Fortinet PSIRT advisories, NVD, and CISA KEV guidance before relying on this document. IOCs listed may rotate — confirm currency before operationalising.

1. Executive Summary

CVE-2026-35616 is a critical (CVSS 9.1) pre-authentication API bypass vulnerability in Fortinet FortiClient Endpoint Management Server (EMS). By forging a single HTTP header — X-SSL-CLIENT-VERIFY — an unauthenticated remote attacker can completely bypass the Django middleware authentication layer and issue privileged administrative API commands against the EMS server. The vulnerability was first observed being actively exploited in the wild on 31 March 2026 by watchTower, several days before Fortinet published its advisory on 4 April 2026, classifying it as a zero-day at time of discovery. CISA added it to the Known Exploited Vulnerabilities catalog on 6 April 2026.

The threat landscape around this vulnerability is especially serious because active exploitation has been linked to a named malware campaign. Arctic Wolf documented a threat cluster abusing CVE-2026-35616 to deliver the EKZ Infostealer — a credential-harvesting payload disguised as a legitimate Fortinet endpoint patch (FortiEndpoint_Patch.exe) — pushed silently to all managed endpoints via the trusted EMS software distribution channel. This transforms a server-side authentication bypass into an enterprise-wide endpoint compromise: every device managed by the vulnerable EMS instance becomes a potential victim of credential theft from Chrome, Firefox, and Edge, including session cookies and autofill data.

Organisations running FortiClient EMS 7.4.5 or 7.4.6 must apply the out-of-band hotfix or upgrade to 7.4.7 immediately. Detection teams should hunt for anomalous EMS log entries, GUID-named .cmd files in FortiClient script paths, and PowerShell execution chains originating from fortitray.exe or ipsec.exe. Given the CISA KEV listing and confirmed active exploitation, this vulnerability should be treated as already exploited until retrospective hunting confirms otherwise.

Attribute	Detail
CVE ID	CVE-2026-35616
Disclosure Date	4 April 2026 (Fortinet advisory) — zero-day exploited from 31 March 2026
Vulnerability Type	Improper Access Control / Pre-Authentication API Bypass (CWE-284)
Affected Component	Fortinet FortiClient EMS — Django middleware X-SSL-CLIENT-VERIFY header
CVSSv3 Score	9.1 — CRITICAL (Fortinet) / 9.8 (NVD)
Attack Vector	Network (AV:N)
Attack Complexity	Low (AC:L)
Privileges Required	None (PR:N)

User Interaction	None (UI:N)
Exploit Status	Active exploitation in the wild — CISA KEV listed 6 April 2026. Public PoC available (GitHub: keraattin/CVE-2026-35616)
Zero-Day	Yes — exploited before Fortinet advisory; out-of-band patch released
Patch Available	Yes — hotfix for 7.4.5/7.4.6; permanent fix in 7.4.7
Associated Malware	EKZ Infostealer (FortiEndpoint_Patch.exe) — credential harvester for Chrome, Firefox, Edge

2. Vulnerability Details

2.1 Root Cause

The root cause is a trust delegation flaw in the FortiClient EMS Django web application's middleware authentication stack. FortiClient EMS uses mutual TLS (mTLS) certificate verification to authenticate requests from FortiGate fabric devices, and the Django middleware validates client certificates by reading certificate metadata from an HTTP header — specifically X-SSL-CLIENT-VERIFY — that is expected to be set exclusively by a trusted upstream reverse proxy.

However, the application fails to restrict this header to trusted proxy sources only. An unauthenticated attacker who can send HTTP requests directly to the EMS API can include a crafted X-SSL-CLIENT-VERIFY header with an arbitrary certificate identifier (e.g., the value "fortinet-ca2") in their request. The Django middleware processes this attacker-controlled header as if it were a legitimate certificate verification result from the trusted proxy, granting the request the same authentication context as a valid FortiGate fabric device — effectively full administrative API access.

This pattern — trusting user-controlled headers for authentication decisions — is a well-understood class of vulnerability in reverse-proxy architectures. The fix requires the application to only accept certificate metadata from authenticated, internal proxy hops and to reject or strip such headers from any direct client-facing request.

2.2 Affected Products

Product	Affected Versions	Remediation	Status
Fortinet FortiClient EMS	7.4.5	Apply out-of-band hotfix or upgrade to 7.4.7	VULNERABLE
Fortinet FortiClient EMS	7.4.6	Apply out-of-band hotfix or upgrade to 7.4.7	VULNERABLE
Fortinet FortiClient EMS	7.4.7+	N/A — permanent fix included	Fixed
Fortinet FortiClient EMS	7.2.0 through 7.2.7	Upgrade to 7.2.8	VULNERABLE

Fortinet FortiClient EMS	7.2.8+	N/A — fix included	Fixed
Fortinet FortiClient EMS	7.4.0 through 7.4.1	Upgrade to 7.4.2 or later	VULNERABLE (earlier variant)

2.3 Attack Scenarios

Scenario 1 — Direct API Exploitation for Configuration Access: An attacker with network access to the FortiClient EMS web interface sends a crafted HTTP POST request to an authenticated API endpoint, including the header "X-SSL-CLIENT-VERIFY: fortinet-ca2". The Django middleware accepts this as a verified fabric device certificate, grants Site Admin API access, and returns sensitive configuration data including managed endpoint details, network policies, and deployment credentials. This reconnaissance output is used to plan subsequent lateral movement across the managed endpoint fleet.

Scenario 2 — EKZ Infostealer Delivery via Malicious Software Package: Following authentication bypass, the attacker uploads a malicious software package disguised as a Fortinet endpoint patch (FortiEndpoint_Patch.exe) to the EMS software repository. The EMS platform distributes this package silently to all managed endpoints via the trusted FortiClient software update channel. On each endpoint, fortitray.exe or ipsec.exe executes cmd.exe, which launches PowerShell to silently execute the infostealer. The EKZ Infostealer harvests Chrome, Firefox, and Edge credentials, session cookies, and autofill data, writing results to %ProgramData%log.txt before exfiltrating on a timed schedule to 83.138.53[.]110.

Scenario 3 — Persistent Backdoor via EMS Admin Account Creation: After bypassing authentication, the attacker creates a new EMS administrator account or API token through the unauthenticated API. This provides persistent access to the EMS platform that survives patching unless the backdoor account is explicitly removed. The attacker uses persistent EMS access to monitor managed endpoint deployments, push additional tooling, and maintain presence across the organisation's entire managed endpoint estate.

2.4 CVSS v3.1 Breakdown

Metric	Value	Rationale
Attack Vector	Network (N)	Exploitable remotely from any host that can reach the EMS management interface
Attack Complexity	Low (L)	Single forged HTTP header — no special conditions, race windows, or prior knowledge required
Privileges Required	None (N)	Zero authentication — attacker crafts one header value and sends unauthenticated request
User Interaction	None (N)	Fully server-side exploitation; no victim interaction needed at any stage
Scope	Unchanged (U)	Impact contained within the EMS application boundary (though enables downstream endpoint compromise)
Confidentiality	High (H)	Full administrative API access

		exposes all managed endpoint configs, credentials, and EMS data
Integrity	High (H)	Attacker can modify software packages, policies, and configurations for all managed endpoints
Availability	High (H)	EMS platform and all managed endpoint policies can be disrupted or destroyed

3. Threat Landscape & Context

CVE-2026-35616 is distinguished from most critical vulnerabilities by its confirmed active exploitation as a zero-day, its CISA KEV listing within days of advisory publication, and its documented linkage to a targeted malware delivery campaign. The combination of an unauthenticated RCE-equivalent primitive on a trusted endpoint management platform with an active threat actor weaponising it for credential harvesting makes this a tier-one incident response priority for any organisation running FortiClient EMS.

The exploitation technique is technically unsophisticated — forging a single HTTP header — which means the barrier to entry for less capable threat actors is extremely low after the advisory publication. A public PoC including Python and Nmap NSE detection scripts was published on GitHub shortly after the advisory, further lowering the exploitation threshold. Mass scanning of internet-facing FortiClient EMS instances should be assumed to have begun within hours of advisory publication.

The EKZ Infostealer campaign documented by Arctic Wolf is particularly concerning from a defender's perspective because the malware is delivered through a trusted channel — the FortiClient software update mechanism — that endpoint security tools are unlikely to flag. Endpoints receiving packages from their own EMS server implicitly trust that content, meaning the attacker effectively bypasses endpoint AV and EDR detection by riding the legitimate management plane. The infostealer's credential exfiltration targets Chrome AppBound Encryption (ABE), a relatively new Chrome security feature added to protect stored passwords, indicating the actor has invested in modern bypass techniques.

The C2 infrastructure observed at 83.138.53.[.]110 should be blocked at the perimeter and added to threat intelligence platforms immediately. FortiClient EMS is widely deployed in mid-market and enterprise environments as a central endpoint management hub, making this a high-value target with significant blast radius potential for any threat actor achieving exploitation.

4. Mitigation

4.1 Apply the Vendor Patch (Primary Remediation)

Fortinet released an out-of-band hotfix for FortiClient EMS 7.4.5 and 7.4.6 that addresses the vulnerability without requiring system downtime. A permanent fix is included in 7.4.7. Apply via Fortinet support channels:

```
# Verify current FortiClient EMS version
# Administration Console -> System Information -> Firmware Version

# Target versions:
# 7.4.x branch -> 7.4.7 (permanent fix) or apply 7.4.5/7.4.6 hotfix
```

```
# 7.2.x branch -> 7.2.8
# 7.4.0 / 7.4.1 -> 7.4.2 or later
```

Reference Fortinet PSIRT advisory: FG-IR-2026-35616. Download from Fortinet Support Portal. Validate installation by checking version post-update and reviewing the EMS web server access logs for absence of exploitation indicators.

4.2 Interim Workaround — Restrict Management Interface Access

If immediate patching is not possible, restrict network access to the FortiClient EMS management interface to authorised administrator source IPs only. The vulnerability requires HTTP access to the EMS API, so network-layer isolation is an effective compensating control:

```
# Block external access to FortiClient EMS management port (default TCP
443/8013)
# Allow only: admin workstations, jump hosts, FortiGate fabric devices
# Apply at: perimeter firewall, host-based firewall, or EMS host network
ACL

# Windows Firewall (on EMS host) — restrict inbound to admin CIDR
netsh advfirewall firewall add rule name="EMS-Admin-Only" ^
    dir=in action=allow protocol=tcp localport=443 ^
    remoteip=10.0.0.0/24
netsh advfirewall firewall add rule name="EMS-Block-Other" ^
    dir=in action=block protocol=tcp localport=443
```

4.3 Header Stripping at Reverse Proxy

As an additional defence-in-depth control, configure any upstream reverse proxy or load balancer in front of FortiClient EMS to strip or overwrite the X-SSL-CLIENT-VERIFY header from all inbound requests before forwarding to the application. This prevents the forged header from reaching the Django middleware regardless of whether the application patch has been applied:

```
# Nginx — strip X-SSL-CLIENT-VERIFY from all client requests
proxy_set_header X-SSL-CLIENT-VERIFY "";

# Apache — remove the header before proxying
RequestHeader unset X-SSL-CLIENT-VERIFY
```

4.4 Post-Exploitation Remediation Steps

Given confirmed active exploitation in the wild, organisations should assume potential compromise and take the following steps in addition to patching: audit all EMS administrator accounts and API keys — revoke any not in the authorised list; review software packages deployed via EMS in the last 60 days for unexpected or newly added packages; inspect all managed endpoints for the EKZ Infostealer indicators of compromise listed in Section 5; rotate all credentials that may have been harvested from managed endpoints (browser-stored passwords, session cookies); and block 83.138.53[.]110 at all egress points immediately.

5. Detection

5.1 Host & Application Behavioural Indicators

EMS server indicators: The following log entry in the FortiClient EMS web server log (typically at C:\Program Files\Fortinet\FortiClientEMS\logs\ indicates an active exploitation attempt: "Certificate not found in request header". A follow-on entry indicating a successful bypass reads: "Certificate user: fortinet-ca2 FortiGate: Fabric device (SN=fortinet-ca2) successfully updated". These two entries appearing within seconds of each other from a non-FortiGate source IP is a high-confidence exploitation indicator.

Managed endpoint indicators for EKZ Infostealer: PowerShell execution initiated by fortitray.exe or ipsec.exe; creation of FortiEndpoint_Patch.exe in a temporary or unexpected path; creation of log.txt in %ProgramData%; GUID-named .cmd files appearing in C:\Program Files\Fortinet\FortiClient\logs\Tracescripts\; outbound HTTP/S connections to 83.138.53.[.]110; new local administrator accounts or scheduled tasks created without a corresponding change ticket.

5.2 Sigma Rules

5.2.1 EMS Server — Forged X-SSL-CLIENT-VERIFY Exploitation Attempt

```
title: FortiClient EMS Auth Bypass via Forged Certificate Header (CVE-2026-35616)
id: c9d8e7f6-5a4b-3c2d-1e0f-9a8b7c6d5e4f
status: stable
description: >
  Detects CVE-2026-35616 exploitation — forged X-SSL-CLIENT-VERIFY header
  reaching the FortiClient EMS application from a non-FortiGate source IP.
references:
  - https://watchtowr.com/resources/fortinet-forticlient-ems-zero-day-cve-2026-35616-active-exploitation-underway/
  - https://nvd.nist.gov/vuln/detail/CVE-2026-35616
author: Lost Boys Cyber
date: 2026-05-28
tags:
  - attack.initial_access
  - attack.t1190
  - attack.privilege_escalation
  - attack.t1078
logsource:
  category: webserver
  product: forticlient_ems
detection:
  selection:
    cs-headers|contains: "X-SSL-CLIENT-VERIFY"
    cs-status|startswith: "20"
  filter_legit_fortigate:
    c-ip|cidr:
      - "10.0.0.0/8"
      - "172.16.0.0/12"
      - "192.168.0.0/16"
    condition: selection and not filter_legit_fortigate
falsepositives:
```

```

- Internal FortiGate fabric devices in non-RFC1918 address space (add
their IPs to filter)
level: critical

```

5.2.2 Endpoint — EKZ Infostealer Execution Chain

```

title: EKZ Infostealer Execution via FortiClient EMS Managed Package
(CVE-2026-35616)
id: d1e2f3a4-b5c6-7d8e-9f0a-1b2c3d4e5f6a
status: experimental
description: >
  Detects EKZ Infostealer execution chain observed in CVE-2026-35616
exploitation
  campaigns - fortitray.exe or ipsec.exe spawning cmd.exe then PowerShell.
references:
  - https://arcticwolf.com/resources/blog/forticlient-ems-exploited-via-
cve-2026-35616-to-deliver-ekz-infostealer-disguised-as-a-fortinet-patch/
author: Lost Boys Cyber
date: 2026-05-28
tags:
  - attack.execution
  - attack.t1059.001
  - attack.defense_evasion
  - attack.t1036.005
  - attack.collection
  - attack.t1555.003
logsource:
  category: process_creation
  product: windows
detection:
  selection_parent:
    ParentImage|endswith:
      - "\fortitray.exe"
      - "\ipsec.exe"
    Image|endswith:
      - "\cmd.exe"
      - "\powershell.exe"
      - "\pwsh.exe"
  selection_payload:
    CommandLine|contains:
      - "FortiEndpoint_Patch"
      - "FortiClientEMS"
      - "-WindowStyle Hidden"
      - "-ExecutionPolicy Bypass"
  condition: selection_parent or selection_payload
falsepositives:
  - Legitimate FortiClient software updates (validate against known-good
package hashes)
level: critical

```

5.3 Windows Event Log & EDR Indicators

Event / Source	Relevance	Key Fields
----------------	-----------	------------

Windows Event 4688 / Sysmon 1	fortitray.exe or ipsec.exe spawning cmd.exe -> powershell.exe	ParentImage, Image, CommandLine
Windows Event 4688 / Sysmon 1	PowerShell executing FortiEndpoint_Patch.exe silently	CommandLine (-WindowStyle Hidden / -ExecutionPolicy Bypass)
Sysmon Event 11 (File Create)	FortiEndpoint_Patch.exe written to %TEMP% or unexpected path	TargetFilename, Image
Sysmon Event 11 (File Create)	log.txt created in %ProgramData%	TargetFilename, Image
Sysmon Event 11 (File Create)	GUID-named .cmd file in FortiClient logsTracescripts path	TargetFilename
Sysmon Event 3 (Network)	Outbound connection to 83.138.53[.]110 from FortiClient process	DestinationIp, Image
Windows Event 4720	New local administrator account created post-exploitation	SubjectUserName, TargetUserName
Windows Event 4698	New scheduled task created by unexpected process	TaskName, SubjectUserName
EMS web server log	"Certificate not found in request header" then "fortinet-ca2" entry	Timestamp, source IP, user-agent

5.4 Microsoft Defender for Endpoint (KQL)

```
// CVE-2026-35616 – EKZ Infostealer: FortiClient process spawning shell
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("fortitray.exe", "ipsec.exe")
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe")
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, FileName, ProcessCommandLine
| order by Timestamp desc
```

```
// CVE-2026-35616 – EKZ Infostealer: credential harvest file (log.txt in
ProgramData)
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has "ProgramData" and FileName =~ "log.txt"
| where InitiatingProcessFileName !in~
("notepad.exe", "vscode.exe", "code.exe")
| project Timestamp, DeviceName, AccountName, FolderPath, FileName,
    InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc
```

```
// CVE-2026-35616 – C2 connection to known EKZ Infostealer infrastructure
DeviceNetworkEvents
```

```
| where Timestamp > ago(30d)
| where RemoteIP == "83.138.53.110"
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName,
|       RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc

// CVE-2026-35616 - GUID-named .cmd files in FortiClient script path
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("FortiClient\\logsTracescripts", "FortiClient\\
\\logs")
| where FileName matches regex @"^[{}?][0-9a-fA-F]{8}-([0-9a-fA-F]{4}-){3}
[0-9a-fA-F]{12}[{}]?\.cmd$"
| project Timestamp, DeviceName, FolderPath, FileName,
InitiatingProcessFileName
| order by Timestamp desc
```

5.5 YARA Rule — EKZ Infostealer

```
rule EKZ_Infostealer_CVE_2026_35616 {
  meta:
    description = "Detects EKZ Infostealer payload delivered via
CVE-2026-35616 FortiClient EMS exploitation"
    author      = "Lost Boys Cyber"
    date        = "2026-05-28"
    reference    = "https://arcticwolf.com/resources/blog/forticlient-
ems-exploited-via-cve-2026-35616-to-deliver-ekz-infostealer-disguised-as-a-
fortinet-patch/"
    severity     = "critical"
  strings:
    $s1 = "FortiEndpoint_Patch" ascii wide nocase
    $s2 = "log.txt" ascii wide
    $s3 = "83.138.53" ascii
    $s4 = "EKZ" ascii wide
    $s5 = "Chrome" ascii wide
    $s6 = "AppBound" ascii wide nocase
    $s7 = "logsTracescripts" ascii wide nocase
    $s8 = "X-SSL-CLIENT-VERIFY" ascii wide
  condition:
    uint16(0) == 0x5A4D and
    (2 of ($s1, $s2, $s3, $s4) or
     ($s5 and $s6 and $s2) or
     $s8)
}
```

6. Indicators of Compromise

The following IOCs are associated with CVE-2026-35616 active exploitation and the EKZ Infostealer campaign as documented by Arctic Wolf (May 2026). Validate currency of all IOCs before operationalising — threat actor infrastructure may rotate.

IOC Type	Value	Confidence	Context
IPv4 (C2)	83.138.53[.]110	High	EKZ Infostealer exfiltration C2 — Arctic Wolf attribution
Filename	FortiEndpoint_Patch.exe	High	EKZ Infostealer payload disguised as Fortinet patch
File path	%ProgramData%\log.txt	High	EKZ credential harvest output file
File pattern	GUID-named .cmd files	High	Drop location: FortiClient\logs\Tracescripts\ path
HTTP header	X-SSL-CLIENT-VERIFY: fortinet-ca2	High	Exploitation header value used in bypass PoC
EMS log string	Certificate not found in request header	High	EMS server log indicator of exploit attempt
EMS log string	SN=fortinet-ca2 successfully updated	High	EMS server log indicator of successful bypass
Process chain	fortitray.exe -> cmd.exe -> powershell.exe	High	EKZ Infostealer execution chain on managed endpoints
Process chain	ipsec.exe -> cmd.exe -> powershell.exe	High	Alternate EKZ execution chain variant

7. Threat Hunting

Given CISA KEV listing and confirmed active exploitation, adopt a breach-assumed posture for these hunts. Run across at least 60-90 days of historical telemetry. The zero-day window (31 March – 4 April 2026) means exploitation may predate your advisory awareness.

7.1 Hunt: Forged Header Exploitation Attempts Against EMS Server

Hypothesis: If CVE-2026-35616 was exploited, the FortiClient EMS web server logs will contain the string "Certificate not found in request header" followed within seconds by "fortinet-ca2 successfully updated" from a source IP outside the expected FortiGate device range.

Data sources required: FortiClient EMS web server logs, SIEM ingestion of EMS application logs, network proxy logs.

```
# Search EMS web server logs directly on the EMS host (Windows)
Select-String -Path "C:\Program Files\Fortinet\FortiClientEMS\logs\*.log" -Pattern "Certificate not found|fortinet-ca2"
```

```
# Correlate timestamps – exploitation indicator is both strings within 10
seconds
# from the same source IP outside known FortiGate management IPs
```

7.2 Hunt: EKZ Infostealer Execution on Managed Endpoints

Hypothesis: If the EKZ Infostealer was deployed via EMS, managed endpoints will show fortitray.exe or ipsec.exe spawning PowerShell with a hidden window flag, followed by file creation events in %ProgramData% and outbound connections to 83.138.53[.]110.

```
DeviceProcessEvents
| where Timestamp > ago(90d)
| where InitiatingProcessFileName in~ ("fortitray.exe","ipsec.exe")
| where FileName in~ ("powershell.exe","cmd.exe","pwsh.exe")
| summarize Count=count(), Devices=make_set(DeviceName)
|   by InitiatingProcessFileName, FileName, ProcessCommandLine
| where Count > 0
| order by Count desc
```

7.3 Hunt: Credential Harvest Artefacts on Managed Endpoints

Hypothesis: EKZ Infostealer writes harvested credentials to %ProgramData%\log.txt. Any endpoint with an unexpected log.txt in ProgramData created by a FortiClient-related process is a strong indicator of compromise.

```
DeviceFileEvents
| where Timestamp > ago(90d)
| where FileName =~ "log.txt"
| where FolderPath startswith "C:\\ProgramData"
| where InitiatingProcessFileName !in~
("notepad.exe","vscode.exe","code.exe","python.exe")
| project Timestamp, DeviceName, AccountName, FolderPath,
InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc
```

7.4 Hunt: C2 Exfiltration Traffic to Known IOC

Hypothesis: EKZ Infostealer exfiltrates to 83.138.53[.]110. Any outbound connection to this IP from a managed endpoint running FortiClient is a confirmed compromise indicator. Run this hunt at the network/proxy layer as well as EDR.

```
DeviceNetworkEvents
| where Timestamp > ago(90d)
| where RemoteIP == "83.138.53.110"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Count=count()
|   by DeviceName, InitiatingProcessFileName, RemoteIP, RemotePort
| order by FirstSeen asc
```

7.5 Hunt: Backdoor EMS Accounts and API Keys Created Post-Exploitation

Hypothesis: An attacker with persistent EMS API access may have created backdoor administrator accounts or API tokens. Review EMS account creation events against the authorised user list.

```
# Query FortiClient EMS admin account audit log (EMS Management Console)
# Navigation: Admin -> Audit Log -> Filter: Event Type = "User Created"
```

```
#           Date range: 1 March 2026 to present
# Cross-reference all accounts against your authorised EMS admin register

# Also check API tokens: Admin -> API Tokens
# Revoke any token not in the authorised list
```

8. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	Relevance to CVE-2026-35616
Initial Access	T1190 — Exploit Public-Facing Application	Core exploitation — forged HTTP header bypasses EMS API authentication
Privilege Escalation	T1078 — Valid Accounts	Post-bypass attacker operates with implicit Site Admin privilege
Execution	T1059.001 — Command and Scripting: PowerShell	EKZ Infostealer delivered and executed via hidden PowerShell from FortiClient process
Defense Evasion	T1036.005 — Masquerading: Match Legitimate Name	EKZ payload named FortiEndpoint_Patch.exe to evade user and security tool suspicion
Defense Evasion	T1218 — System Binary Proxy Execution	Legitimate FortiClient binaries (fortitray.exe, ipsec.exe) used to launch payload
Credential Access	T1555.003 — Credentials from Web Browsers	EKZ Infostealer extracts Chrome, Firefox, Edge passwords, cookies, and autofill data
Credential Access	T1539 — Steal Web Session Cookie	EKZ Infostealer specifically targets session cookies for account takeover
Collection	T1005 — Data from Local System	Credentials and autofill data written to log.txt in ProgramData before exfiltration
Exfiltration	T1041 — Exfiltration Over C2 Channel	Harvested credentials exfiltrated to 83.138.53[.]110 on timed schedule
Persistence	T1098 — Account Manipulation	Backdoor EMS admin accounts or API keys may be created for persistent platform access
Lateral Movement	T1072 — Software Deployment Tools	EMS software distribution channel used to push malware to all managed endpoints

9. Recommended Actions Summary

Priority	Action	Owner	Timeline
P1 — Critical	Apply FortiClient EMS hotfix (7.4.5/7.4.6) or upgrade to 7.4.7 / 7.2.8	IT / Patching Team	Immediately — same day
P1 — Critical	Block 83.138.53[.]110 at all egress firewalls, proxies, and DNS	Network / Security Ops	Immediately
P1 — Critical	Restrict EMS management interface to authorised admin IPs only	Network / Security Ops	Within 24 hours
P1 — Critical	Audit all EMS admin accounts and API keys — revoke unauthorised	Cisco / EMS Admin	Within 24 hours
P1 — Critical	Hunt all managed endpoints for EKZ Infostealer IOCs (Section 6)	Threat Hunt / IR Team	Within 24 hours
P2 — High	Deploy Sigma rules for EMS header exploit and EKZ execution chain	SOC / Detection Eng.	Within 48 hours
P2 — High	Deploy KQL rules in MDE / Sentinel for all four hunt queries	SOC / Detection Eng.	Within 48 hours
P2 — High	Force password reset for all users on managed endpoints (credential theft assumed)	IAM / IT	Within 48 hours
P2 — High	Invalidate all web session tokens / force re-authentication (cookie theft assumed)	IAM / IT	Within 48 hours
P2 — High	Review all EMS-deployed software packages for the last 60 days	EMS Admin / Security	Within 72 hours
P3 — Medium	Deploy header-stripping rule at reverse proxy (X-SSL-CLIENT-VERIFY)	Network / Security Eng.	Within 1 week
P3 — Medium	Add EKZ YARA rule to endpoint AV and file scanning pipelines	Threat Intel / SOC	Within 1 week

P3 — Medium	Patch compliance report — % of EMS instances upgraded by asset tier	Vuln. Management	Within 1 week
-------------	---	------------------	---------------

10. References

- [1] Fortinet PSIRT. "FG-IR-2026-35616 — FortiClientEMS Improper Access Control." <https://www.fortiguard.com/psirt/FG-IR-2026-35616>
- [2] watchTowr. "Fortinet FortiClient EMS Zero-Day: CVE-2026-35616 (Active Exploitation Underway)." <https://watchtowr.com/resources/fortinet-forticlient-ems-zero-day-cve-2026-35616-active-exploitation-underway/>
- [3] Arctic Wolf. "FortiClient EMS Exploited via CVE-2026-35616 to Deliver EKZ Infostealer Disguised as a Fortinet Patch." <https://arcticwolf.com/resources/blog/forticlient-ems-exploited-via-cve-2026-35616-to-deliver-ekz-infostealer-disguised-as-a-fortinet-patch/>
- [4] NVD. "CVE-2026-35616 Detail." <https://nvd.nist.gov/vuln/detail/CVE-2026-35616>
- [5] CISA. "Known Exploited Vulnerabilities Catalog — CVE-2026-35616." https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-35616
- [6] Qualys ThreatPROTECT. "Fortinet FortiClientEMS Vulnerability Exploited in the Wild (CVE-2026-35616)." <https://threatprotect.qualys.com/2026/04/06/fortinet-forticlientems-vulnerability-exploited-in-the-wild-cve-2026-35616/>
- [7] Horizon3.ai. "CVE-2026-35616: FortiClient EMS Analysis." <https://horizon3.ai/attack-research/vulnerabilities/cve-2026-35616/>
- [8] Penlign AI. "CVE-2026-35616 in FortiClient EMS — How the Auth Bypass Works and What to Do Now." <https://www.penlign.ai/hackinglabs/cve-2026-35616-in-forticlient-ems-how-the-auth-bypass-works-and-what-to-do-now/>
- [9] Censys. "April 7 Advisory: Improper Access Control Vulnerability in Fortinet FortiClient EMS." <https://censys.com/advisory/cve-2026-35616/>
- [10] GitHub (keraattin). "CVE-2026-35616 — Python & Nmap NSE Detection Scripts." <https://github.com/keraattin/CVE-2026-35616>
- [11] Greenbone. "Fortinet EMS Vulnerabilities Actively Exploited." <https://www.greenbone.net/en/blog/patch-now-2026-35616-and-cve-2026-21643/>
- [12] Security Arsenal. "CVE-2026-35616: FortiClient EMS Actively Exploited — IR Guide and Defensive Hardening." <https://securityarsenal.com/blog/cve-2026-35616-forticlient-ems-actively-exploited-ir-guide-and-defensive-hardening>
- [13] MITRE ATT&CK. "T1190 — Exploit Public-Facing Application." <https://attack.mitre.org/techniques/T1190/>
- [14] MITRE ATT&CK. "T1555.003 — Credentials from Web Browsers." <https://attack.mitre.org/techniques/T1555/003/>
- [15] MITRE ATT&CK. "T1072 — Software Deployment Tools." <https://attack.mitre.org/techniques/T1072/>